

s1.06 — Enterprise remote browser isolation service

Index

- [Interview framing](#)
- [Requirements — IC3 baseline](#)
- [Capacity and consequence — IC3 baseline](#)
- [Architecture and flow — IC3 baseline](#)
- [API and data model — IC3 baseline](#)
- [Isolation and session ownership — IC3 baseline](#)
- [Lifecycle reconciliation — IC3 baseline](#)
- [Failure, operations, and security](#)
- [Alternatives and IC4 stretch](#)
- [Level signal — IC3 baseline vs IC4 stretch](#)
- [Interview pushback and validation](#)
- [Recall card](#)
- [References](#)

Interview framing

- Target: OCI IC3 ownership of a bounded platform component.
 - `IC3 baseline` is what must land in every phase.
 - `IC4 stretch` adds architecture changes under stronger constraints.
 - These are preparation labels, not Oracle's official rubric.
- Evidence: retain the first-hand report attribution in [the bank](#).
 - The architecture below is a proposed interview answer.
 - It does not claim to reproduce Oracle's implementation or an interviewer's accepted answer.
- Why this is hard
 - Naive: run a headless browser in a container per user, relay pixels over a WebSocket, and delete the container when the tab closes.
 - First break: a hostile page escapes the shared kernel, or the browser reaches the instance metadata endpoint and turns the farm into an SSRF platform against the control plane.
 - Second break: the allocator loses a response and leaks workers, a stale token attaches to a recycled worker address, and a disconnect quietly leaves the user browsing unisolated.
 - Minimum primitives
 - A hard isolation boundary per session
 - Egress enforced at connection time after DNS resolution
 - Short-lived generation-bound tokens
 - Durable desired state reconciled against worker inventory.
- 🗨️ “Treat the worker as the attacker; the design is what a compromised worker still cannot reach, and how the control plane proves it is gone.”
- Opening script
 - “I will use disposable isolated browser sessions with explicit user ownership, controlled egress, and a reconciled lifecycle.”
 - “First I confirm the rendering model, whether sessions persist, and which transfers and destinations are in scope.”
 - “Then I size memory, streaming bandwidth, and warm capacity from ten thousand concurrent sessions.”
 - “The deep dive is the isolation boundary, token binding to a session generation, and reconciliation of allocation and destruction.”

- “I will close with failure handling, tenant isolation, and where I would change the design for private sites or multiple regions.”
- Numerical targets below are interview assumptions unless a reference explicitly supplies them.
 - Validate performance targets with the actual payload and deployment topology.

Phase	Clock	Deliverable
Intro and behavioral slice	00:00–05:00	90-second pitch; confirm the prompt
Requirements	05:00–11:00	Rendering model, transfer policy, primary invariant
Estimates and contract	11:00–17:00	Memory, bandwidth, warm pool; session API semantics
Architecture	17:00–30:00	Diagram, control/data plane ownership, one request trace
Deep dive	30:00–45:00	Isolation boundary, token generation binding, reconciler
Operations and tradeoffs	45:00–50:00	Failure table, cleanup proof, tradeoff, wrap script
Wrap-up	50:00–54:00	Four-sentence recap and weakest assumption
Questions for interviewer	54:00–60:00	Two role-specific questions

- Clock note
 - If the interviewer states 45 minutes, drop the intro to 2 minutes and compress each phase proportionally.
 - The interviewer's clock wins over this table.

Requirements — IC3 baseline

- Numerical targets are interview assumptions unless an adjacent primary source states otherwise.

Question	Assumed answer	Why it changes the design
Pixel stream or reconstructed DOM/drawing commands?	Pixel stream	Simple trust boundary; bandwidth becomes the dominant cost
Persistent login state or disposable sessions?	Disposable	No profile storage; cleanup is reprovision, not deletion
Are clipboard, uploads, and downloads permitted?	Disabled until scanning paths exist	Each transfer direction needs its own policy and quarantine path
Are private enterprise sites in scope?	No; Internet-only	Egress blocks private and control-plane ranges outright
Required isolation boundary?	VM/microVM per session	Sets memory cost and allocation latency
Single region or global users?	One region first, residency policy known	Affinity and warm pool are regional; failover is a visible reset
Peak concurrency?	10,000 sessions	Drives memory, egress, and warm-capacity math

- Functional scope
 - Frame the enterprise browser-isolation prompt.
 - Users browse untrusted sites through remote browser sessions.
 - Active site content executes in an isolated worker.
 - The endpoint receives a constrained rendered representation.
 - Input travels back to the remote session.
 - Baseline decisions
 - Use pixel streaming to keep the rendering trust boundary easy to explain.
 - Use disposable per-user sessions.
 - Allow approved Internet destinations through a controlled egress proxy.
 - Disable clipboard and file transfer until their policy/scanning paths are specified.

Requirement	Target	Enforced by
Concurrent sessions	10,000	Regional capacity reservation; per-tenant concurrency quota

Requirement	Target	Enforced by
Warm session allocation	p99 < 5 s	Warm pool of 20% spare workers; allocator returns an operation handle
Input-to-render latency	p99 < 150 ms for users near the region	Regional placement; encoder frame budget; adaptive bitrate
Session-service availability	99.9%	Stateless controllers across fault domains; sessions pinned to one worker
Idle timeout / reconnect grace	15 min / 60 s	Expiry reconciler on the session table
Worker termination after closure	Within 60 s	Lifecycle reconciler; alert on orphan age
Connection token lifetime	60 s, one use, generation-bound	Ticket table with consumed_at; gateway validates generation
Data-plane independence	Existing streams survive a 5 min controller outage when session/policy validity exceeds 5 min	Cached binding plus locally enforced expiry; reconnect still checks authorization

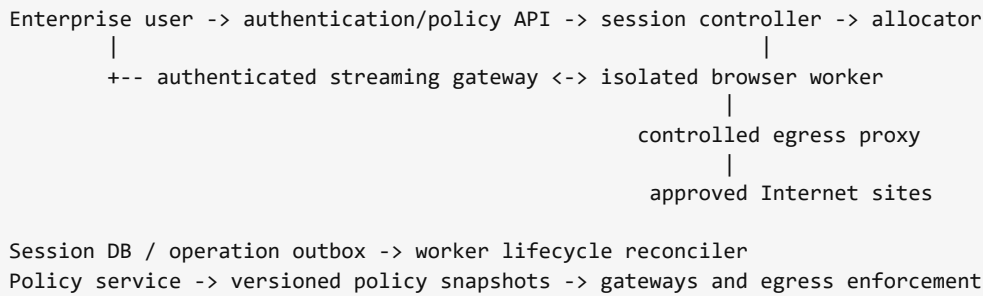
- Invariants
 - Session ownership is bound to authenticated tenant and user.
 - A worker cannot reach control-plane credentials, metadata endpoints, or other tenants.
 - Reused capacity must not expose a prior session's cookies, memory, or files.
 - A disconnect never silently changes the user to unisolated browsing.
- Non-goals
 - Persistent browser profiles across sessions.
 - Private-site connectors into the enterprise network.
 - Transparent live migration of a running session between regions.

Capacity and consequence — IC3 baseline

- Memory
 - Assume 512 MiB reserved per active browser session.
 - $10,000 \times 512 \text{ MiB} = 5,120,000 \text{ MiB} \approx 4.88 \text{ TiB}$.
 - An additional 20% warm capacity increases the reservation to about 5.86 TiB.
 - Real browser footprints and CPU demands must be benchmarked with representative sites.
 - Decision: microVM-per-session is affordable at this scale only on dense hosts
 - CPU per session probably binds before memory, so the benchmark decides host shape, not the memory arithmetic.
- Streaming bandwidth
 - At an assumed average 2 Mbit/s/session, egress is 20 Gbit/s.
 - Animation-heavy sites can exceed this average.
 - Bandwidth can dominate cost before control-plane requests do.
 - Decision: the encoder must adapt bitrate and frame rate per session, and gateways sit near users, because egress is the cost line that scales with usage.
- Session creation
 - With 30 min average lifetime, steady churn is approximately $10,000 / 1,800 = 5.6 \text{ new sessions/s}$.
 - Shift changes or regional recovery create bursts.
 - Warm capacity must cover allocation latency and the expected burst, not just average churn.
 - Decision: size the warm pool to the burst, not the mean
 - 2,000 warm workers absorb a 400/s burst for the 5 s allocation window before latency degrades.
- Placement
 - Begin with one regional pool and explicit affinity.
 - Add regions when user latency or regional resilience requires them.

- Decision: a session is pinned to one worker for its life, so placement is decided once at creation.

Architecture and flow — IC3 baseline



- Session controller (control plane)
 - Authorizes the user and tenant quota.
 - Persists desired session state before requesting worker allocation.
 - Returns an operation handle for asynchronous allocation.
 - Cost: two round trips to reach `READY`, and a reconciler is required because intent and inventory can diverge.
 - Allocator and lifecycle reconciler (control plane)
 - Turns desired state into worker inventory using session ID plus generation as the operation identity.
 - Cost: reconciliation loops consume inventory API budget and add a bounded delay to cleanup.
 - Isolated worker (data plane)
 - Executes hostile web content inside the chosen sandbox boundary.
 - A VM/microVM boundary can reduce shared-kernel exposure compared with a container alone.
 - The design still requires browser and host patching.
 - Cost: slower start and higher memory per session than a shared-kernel container.
 - Streaming gateway (data plane)
 - Routes only to the authorized session owner.
 - Carries interactive traffic without exposing worker management ports.
 - Holds the session-to-worker binding and policy snapshot, so existing streams survive a controller outage.
 - Cost: cached bindings mean revocation propagates with snapshot delay, not instantly.
 - Egress proxy (data plane)
 - Enforces destination policy after DNS resolution and on connection establishment.
 - Rechecks redirect destinations.
 - Blocks private/control-plane address ranges for the baseline Internet-only service.
 - Cost: every outbound connection pays a policy check
 - The proxy is a shared chokepoint that needs its own capacity plan.
 - Policy service (control plane)
 - Publishes versioned snapshots to gateways and egress.
 - Cost: a policy change is eventually consistent across enforcement points.
- Authenticate user and check tenant session quota.
- Persist `ALLOCATING` session with a stable create idempotency key.
- Allocate a worker and bind it to a session generation.
- Load policy and issue a short-lived session-scoped connection token.
- Connect the user to the streaming gateway and current worker.
- Apply egress and interaction policies during browsing.
- On close or expiry, revoke the stream and reconcile worker destruction.

API and data model — IC3 baseline

Surface	Contract	Conflict/error behavior
POST /v1/sessions	URL, desired region; returns session/operation ID with 202	Same idempotency key plus different normalized request returns 409; over quota returns 429
GET /v1/sessions/{id}	Lifecycle and connection readiness	404 for another tenant's ID; owner/administrator authorization
POST /v1/sessions/{id}:connect	Short-lived audience-bound connection token	409 if the session is not READY or DISCONNECTED; token bound to generation and expiry
DELETE /v1/sessions/{id}	Request termination with 202	Idempotent; cannot revive an expired generation
GET /v1/operations/{id}	Allocation/termination result	Distinguish accepted intent from ready worker or observed destruction

State	Key	Fields and invariant
Session	(tenant_id, session_id)	Owner, desired/observed state, worker ID, generation, expiry
Worker assignment	worker_id	At most one live session assignment per worker
Create dedup	(tenant_id, idempotency_key)	Request hash and resulting session ID
Policy	(tenant_id, policy_version)	Allowed destinations, transfer permissions, session limits
Connection ticket	(tenant_id, ticket_hash)	Session ID, generation, expiry, consumed_at; one use
Lifecycle outbox	event_id	Session ID, expected generation, desired action

- Reference DDL
 - Keys and uniqueness match the state table above and the [companion schema](#).
 - Worker inventory, encoder state, input sequence, and frame queues are runtime state on the worker and gateway; only sessions, assignments, tickets, policy, and the outbox are relational.

```

CREATE TABLE policies (
  tenant_id text NOT NULL, policy_version bigint NOT NULL CHECK (policy_version >= 1),
  allowed_destinations jsonb NOT NULL,      -- normalized URL/egress rules, re-checked at connect time
  transfer_permissions jsonb NOT NULL,      -- download, upload, clipboard directions
  max_sessions integer NOT NULL CHECK (max_sessions >= 0),
  created_at timestamptz NOT NULL,
  PRIMARY KEY (tenant_id, policy_version)
);
CREATE TABLE sessions (
  tenant_id text NOT NULL, session_id text NOT NULL, owner_id text NOT NULL,
  policy_version bigint NOT NULL,
  desired_state text NOT NULL CHECK (desired_state IN ('READY','CLOSED')),
  observed_state text NOT NULL
  CHECK (observed_state IN ('ALLOCATING','READY','DISCONNECTED','TERMINATING','CLOSED')),
  worker_id text,                        -- null until a worker is bound
  generation bigint NOT NULL CHECK (generation >= 1),
  expires_at timestamptz NOT NULL, version bigint NOT NULL,
  PRIMARY KEY (tenant_id, session_id),
  FOREIGN KEY (tenant_id, policy_version) REFERENCES policies
);
CREATE INDEX sessions_owner ON sessions (tenant_id, owner_id, observed_state, session_id);
CREATE INDEX sessions_expiry ON sessions (expires_at)
  WHERE observed_state IN ('READY','DISCONNECTED');
CREATE INDEX sessions_reconcile ON sessions (observed_state, session_id)
  WHERE observed_state IN ('ALLOCATING','TERMINATING');
CREATE TABLE worker_assignments (
  worker_id text NOT NULL, tenant_id text NOT NULL, session_id text NOT NULL,
  generation bigint NOT NULL, assigned_at timestamptz NOT NULL,
  PRIMARY KEY (worker_id),                -- at most one live session per worker
  UNIQUE (tenant_id, session_id, generation),
  FOREIGN KEY (tenant_id, session_id) REFERENCES sessions
);
CREATE TABLE session_create_dedup (
  tenant_id text NOT NULL, idempotency_key text NOT NULL,
  request_hash text NOT NULL, session_id text NOT NULL,
  expires_at timestamptz NOT NULL,      -- retained past the client retry horizon
  PRIMARY KEY (tenant_id, idempotency_key),
  FOREIGN KEY (tenant_id, session_id) REFERENCES sessions
);
CREATE INDEX session_create_dedup_expiry ON session_create_dedup (expires_at);
CREATE TABLE connection_tickets (
  tenant_id text NOT NULL, ticket_hash text NOT NULL,  -- hash only, never the ticket
  session_id text NOT NULL, generation bigint NOT NULL,
  expires_at timestamptz NOT NULL, consumed_at timestamptz,
  PRIMARY KEY (tenant_id, ticket_hash),
  FOREIGN KEY (tenant_id, session_id) REFERENCES sessions
);
CREATE INDEX connection_tickets_expiry ON connection_tickets (expires_at) WHERE consumed_at IS NULL;
CREATE TABLE lifecycle_outbox (
  event_id bigint GENERATED ALWAYS AS IDENTITY PRIMARY KEY,
  tenant_id text NOT NULL, session_id text NOT NULL,
  expected_generation bigint NOT NULL,      -- reconciler CAS target; a bumped generation makes the event a
no-op
  desired_action text NOT NULL CHECK (desired_action IN ('ALLOCATE','TERMINATE')),
  created_at timestamptz NOT NULL, sent_at timestamptz,
  FOREIGN KEY (tenant_id, session_id) REFERENCES sessions
);
CREATE INDEX lifecycle_outbox_unsent ON lifecycle_outbox (event_id) WHERE sent_at IS NULL;

```

- Not captured by the DDL
 - Observed worker inventory comes from the inventory API; `worker_assignments` is the intended binding, and the reconciler compares the two.
 - Ticket values, WebRTC/WebSocket stream state, and sandbox cookies or disks never reach SQL.
 - Deviation from the companion: table names follow this file (`sessions`, `connection_tickets`), states are `ALLOCATING/CLOSED` rather than `PROVISIONING/TERMINATED`, and `policies`, `worker_assignments`,

`session_create_dedup`, and `lifecycle_outbox` are added because the state table names them.

- State machine
 - `ALLOCATING` becomes `READY` only after worker health and policy loading succeed.
 - `READY` becomes `DISCONNECTED` during the reconnect grace interval.
 - A valid reconnect returns the same generation to `READY`.
 - Closure, expiry, or revoked access enters `TERMINATING`.
 - Confirmed worker destruction enters `CLOSED`.
- Conventions
 - Every state transition is a compare-and-set on `(session_id, generation, version)`.
 - `202` plus an operation ID is the pattern for allocation and termination
 - The operation reports observed state, not intent.

Isolation and session ownership — IC3 baseline

- Treat the browser worker as potentially compromised.
 - Do not give it tenant-wide cloud credentials.
 - Deny cloud instance metadata access unless a tightly scoped broker explicitly needs it.
 - Separate worker and control-plane networks.
 - Apply CPU, memory, process, and network limits.
 - Concrete assumption: 2 vCPU, 512 MiB, and a per-session egress cap enforced at the proxy.
- Destination checks
 - Parse and normalize the URL at the policy boundary.
 - Resolve through controlled DNS.
 - Enforce the resolved destination at the egress connection.
 - Reapply checks after redirects and reconnects to prevent DNS-rebinding bypass.
 - A URL allowlist checked once at navigation is not egress control
 - The connection-time check is the mechanism.
- Session affinity
 - Browser memory and cookies live in one worker.
 - A replacement gateway may reconnect to that same worker.
 - A failed worker loses volatile page state.
 - Restarting a worker does not transparently recreate a live session.
- Connection tokens
 - Keep lifetime short and audience specific.
 - Validate the current session generation.
 - A stale token cannot attach to a recycled worker address.
 - Possession of a session ID alone never grants access.
 - Exact failure: a gateway that validates the token signature but not the generation lets a 60 s-old ticket reach whichever session now owns the recycled worker.
- Transfer policies
 - Downloads enter quarantine and policy/scanning before endpoint delivery.
 - Uploads have size and type limits.
 - Clipboard directions are independently controlled.
 - Pixel rendering does not prevent a user from typing credentials into a phishing page.

Lifecycle reconciliation — IC3 baseline

```
RECONCILE(session):
  read desired state, generation, and current reconciler owner epoch
  if allocating and no matching worker exists:
    allocate using session ID + generation as operation identity
  if duplicate workers exist:
    retain one valid assignment and terminate extras
  if terminating or expired:
    revoke connect tokens / routing
    terminate all workers for this generation
    conditionally mark closed only after destruction is observed
    require the same session generation and current reconciler owner epoch
```

- Consistency boundary
 - The session table holds desired state and is the source of truth.
 - Worker inventory is observed state and may lag or contain orphans.
 - The reconciler is the only writer that moves observed state toward desired state.
- Concurrency
 - Each reconcile pass is a compare-and-set on the session generation.
 - Reconnecting to the same live worker keeps the session generation and consumes a fresh one-use connection ticket.
 - Reallocation or security invalidation advances the generation and fences old workers and tickets.
- No session reuse before destruction/clean reset is established.
 - Reprovisioning an ephemeral worker is easier to defend than best-effort deletion of profile files.
 - Persistent profiles need separate encrypted tenant-scoped storage and a defined retention policy.
- Exact failure
 - Marking `CLOSED` when the terminate request is accepted, rather than when destruction is observed, lets the allocator reuse a worker that still holds the previous session's cookies.
 - The reconciler therefore treats a `202` from the inventory API as intent and polls for the observed result.

Failure, operations, and security

Failure	Blast radius	Detection	Degraded behavior	Recovery
Allocator crashes after create	One session	Desired/observed mismatch	Session remains allocating	Reconcile operation identity; remove duplicate workers
Browser worker crashes	Its session	Worker health and stream loss	Explain session reset; no unisolated fallback	Create fresh session after authorization
Gateway disconnects	Its streams	Stream heartbeat	Reconnect within grace to same live worker	Replace gateway and validate generation
Session DB or controller unavailable (control plane)	New sessions and terminations	Controller error rate, outbox age	Existing streams continue on cached bindings; no new sessions	Fail over replica; reconciler drains the outbox
Policy service unavailable	New/expired policies	Snapshot age	Existing sessions obey bounded cached policy; reject unsafe new authorization	Refresh policy and terminate revoked sessions
Egress proxy unavailable	Its sessions' outbound traffic	Proxy health, connection failures	Pages fail closed; no direct egress path exists	Replace proxy capacity; sessions resume without reset
Region loses capacity	Regional sessions	Allocation latency and spare capacity	Reject or queue new sessions with deadline	Route new sessions elsewhere under residency policy

Failure	Blast radius	Detection	Degraded behavior	Recovery
Worker cleanup fails	Residual resource/data	Orphan inventory	Worker stays quarantined and unavailable for reuse	Retry termination and alert on age
Expensive malicious page	Its resource quota	CPU/memory/network limits	Throttle or terminate that session	Patch and replenish clean capacity

- Observe
 - Allocation latency and warm-pool depth.
 - Orphan worker count and oldest orphan age.
 - Oldest `TERMINATING` session.
 - Egress policy denials by tenant.
 - Stream reconnect rate and generation mismatches.
 - Log lifecycle and policy decisions
 - Avoid recording page contents and credentials by default.
 - Restrict access to destination history according to the product's privacy policy.
- Retry discipline
 - Clients retry create and connect with backoff and jitter under the same idempotency key.
 - The reconciler retries inventory calls indefinitely with backoff
 - Termination is never abandoned.
 - A `409` generation conflict is a signal to re-read state, not to retry the same request.
- Tenant isolation
 - Per-tenant quotas on concurrent sessions, memory, and egress bandwidth.
 - Worker execution environments are isolated per session.
 - A host may serve multiple isolated environments only under the declared VM/sandbox boundary.
 - Different tenants never share one live browser profile or session environment.
 - A tenant's token receives `404` on another tenant's session IDs, not `403`, to avoid existence leaks.
 - Policy snapshots are tenant-scoped
 - One tenant's allowlist cannot widen another's egress.
- Rollout and rollback safety
 - Patch by draining old worker images and allocating new generations
 - Running sessions finish on the old image.
 - Roll controllers and gateways by fault domain
 - Cached bindings keep streams alive through the deploy.
 - Policy schema changes ship with a version
 - Enforcement points reject an unknown version rather than failing open.

Alternatives and IC4 stretch

Option	What it is	Strength	Weakness	Choose when
Pixel stream	Remote render sent as images/video	Simple active-content boundary	Bandwidth, latency, accessibility cost	Baseline hostile-content isolation
Sanitized DOM or drawing commands	Reconstruct safe representation	Potentially lower bandwidth	Renderer/sanitizer attack surface and compatibility	Product can own and validate this complexity
Per-session VM boundary	Separate guest isolation	Reduces shared-kernel exposure	Startup and resource cost	Strong enterprise isolation requirement
Shared-kernel container	Process/resource isolation	Fast and dense	Kernel becomes shared trust boundary	Risk model permits and hardening is demonstrated
Secure web gateway only	Inspect/filter requests	Lower execution cost	Web code still runs on endpoint	Isolation is unnecessary for the threat model

- IC4 stretch — negotiated cuts
 - Defer persistent profiles to simplify cross-tenant cleanup.

- Defer private-site connectors to simplify egress policy.
- Explain the user convenience those cuts sacrifice.
- IC4 stretch — multi-region placement
 - Place new sessions close to the user while honoring residency.
 - An existing session remains pinned unless application-level restart is acceptable.
 - Regional failover means new sessions plus a visible reset, not transparent memory migration.
- IC4 stretch — 10× load
 - 100,000 sessions imply about 48.8 TiB of reserved memory and 200 Gbit/s of egress at the same assumptions.
 - Shard the allocator and session table by cell
 - One cell's inventory API budget must not throttle another.
 - Egress cost now dominates
 - Bitrate adaptation and idle-frame suppression save more than more hosts.
- IC4 stretch — cost and blast radius
 - Track per-tenant concurrency, memory, and egress budgets separately.
 - Cell the worker fleet so a bad image or kernel patch stalls one cell, not the region.
 - Keep enough warm capacity to absorb the drain wave during a patch.
- Weakest assumption
 - 512 MiB and 2 Mbit/s per session are averages
 - Media-heavy enterprise workloads can double both and halve effective capacity.
 - Mitigation: benchmark with representative sites, enforce per-session limits so one heavy session cannot starve neighbors, and alarm on warm-pool depth.
- Over-engineering warning
 - Do not claim remote browser isolation eliminates phishing or every browser/sandbox escape.
 - Do not build live VM migration for regional failover when a visible session reset is acceptable.
- Mechanism reference
 - [Cloudflare Browser Isolation](#) documents remote active-content execution and controlled interactions.
 - The pixel-stream/VM design here is an interview choice, not a claim about Cloudflare's internal implementation.

Level signal — IC3 baseline vs IC4 stretch

Phase	IC3 must land	IC4 adds	Separating signal
Requirements	Rendering model, disposable sessions, transfer policy, Internet-only egress	Names the cuts and what each one buys	Negotiates scope instead of accepting it
Estimates	Memory, egress, churn, warm pool	Lets the burst size the warm pool; names the heavy-site case	A number changes the host shape or pool size
Architecture	Controller, allocator, gateway, worker, egress proxy with one trace	Control/data plane split so streams survive a controller outage	Every component has a mechanism and a price
Deep dive	Worker as attacker, connection-time egress, generation-bound tokens, reconciler	Observed-versus-intended destruction; generation CAS across reconnect	Reasons across the DB and inventory boundary
Operations	Failure table, orphan alarms, tenant quotas	Cells, image drain by generation, fail-closed policy versions	Volunteers the cleanup proof before being asked
Wrap	Recap and tradeoff	Names the per-session averages as the weakest assumption	Identifies the flaw before the interviewer does

Interview pushback and validation

- Q1: Why are containers not the entire security story?
 - **IC3 baseline**

- Hostile code still interacts with a shared host kernel.
- **IC4 stretch**
 - Select the isolation boundary against the tenant threat model and patch/escape blast radius.
- Q2: A user reconnects after the worker address is reused.
 - **IC3 baseline**
 - Session generation and token audience must match the current assignment.
 - **IC4 stretch**
 - Revoke routing and credentials before recycling capacity.
- Q3: The allocator created a worker but lost the response.
 - **IC3 baseline**
 - Reconcile using stable session/generation identity.
 - **IC4 stretch**
 - Inventory and remove orphan resources even after the originating operation expires.
- Q4: The requirement changes to private enterprise applications.
 - **IC3 baseline**
 - Add an authorized private connector rather than allowing arbitrary internal destinations.
 - **IC4 stretch**
 - Isolate connectors per tenant and enforce destination identity at that boundary.
- Q5: Can a region fail without disrupting sessions?
 - **IC3 baseline**
 - Volatile browser state is lost in the baseline.
 - **IC4 stretch**
 - Negotiate restart semantics before proposing expensive state replication.
- Q6: What happens if the user closes the tab abruptly?
 - **IC3 baseline**
 - Stream timeout starts a reconnect grace period, then termination.
 - **IC4 stretch**
 - Desired-state reconciliation cleans up resources even if every notification was lost.
- Q7 (premise reversal): Why isolate at all instead of a secure web gateway with URL filtering?
 - **IC3 baseline**
 - A gateway inspects requests but the page still executes on the endpoint, so a zero-day in the local browser is unmitigated.
 - **IC4 stretch**
 - Choose the gateway when the threat model accepts endpoint execution
 - The deciding variable is whether the endpoint is trusted, not the cost of the farm.
- Q8: The session database is down
 - Do users lose their browsers?
 - **IC3 baseline**
 - No
 - Gateways hold the session-to-worker binding, so existing streams continue while new sessions and terminations wait.
 - **IC4 stretch**
 - Bound the cached-binding lifetime so a revoked user cannot browse for longer than the snapshot age during the outage.
- Validation scenarios
 - Cross-tenant session-ID access.
 - Stale connection token against a recycled worker.
 - Redirect and DNS-rebinding attempts to blocked addresses.
 - Duplicate session creation after timeout.

- Worker crash during an authenticated site session.
- Cleanup failure followed by allocator reuse attempt.
- Controller outage while a user reconnects within the grace window.

Recall card

- “Execute untrusted content remotely and keep the worker outside the control-plane trust boundary.”
- “Bind every stream to tenant, user, session, and generation.”
- “Use durable desired state to reconcile allocation and destruction.”
- “Availability failures may reset a session, but never silently bypass isolation.”
- “Closed means destruction was observed, not requested.”
- Wrap-up script
 - “The design is disposable per-session workers behind an authenticated streaming gateway, with a controlled egress proxy and a controller that persists desired state before allocating.”
 - “The key invariant is that a worker is treated as compromised, so it cannot reach credentials, metadata, or other tenants, and a session is closed only when destruction is observed.”
 - “The main tradeoff is VM-per-session isolation, which buys a hard boundary at the price of memory and allocation latency.”
 - “My weakest assumption is the per-session memory and bandwidth average; I would benchmark representative sites before committing host shape.”

References

- [Ranked question and report provenance.](#)
- [OCI role framing.](#)
- [Detailed API and schema companion.](#)
- Reference check: 2026-09-09.
 - Official documentation supports the mechanisms cited next to each link.
 - Capacity values and architecture choices remain proposed interview assumptions.
- [Cloudflare remote browser isolation](#): remote content execution and interaction policy.
- [OCI security overview](#): control-plane and tenant isolation context.
- [OCI instance metadata service](#): the endpoint a worker must be prevented from reaching.